2026

BANCO PICHINCHA

Instructivo de Configuración

Prompt StackHawk.

Contenido

Información relacionada a la configuración del prompt de StackHawk 3
Equipo de trabajo 3
Datos del proyecto 3
Resumen 3
La descarga y configuración del CLI de la herramienta de StackHawk en su versión actual 4
Configuración previa de StackHawk 6
Uso del PROMPT de StackHawk + GitHub Copilot 8
Conclusión 11

Información relacionada a la configuración del prompt de StackHawk

Equipo de trabajo

Empresa	Nombre	Cargo	Contacto
Banco Pichincha	Darío Guevara	Experto desarrollo seguro	saguevar@pichincha.com
Banco Pichincha	Cristian Pillajo	Ingeniero desarrollo seguro	crpillaj@pichincha.com

Datos del proyecto

Proyecto	Instructivo de configuración prompt de StackHawk.
Fecha de creación	01/12/2025
Fecha de modificación	15/01/2026

Resumen

Una vez realizado las capacitaciones en conjunto entre Desarrollo Seguro y equipos de desarrollo en el uso del prompt de StackHawk, en cual, se indicó como utilizar el prompt de StackHawk que ya posee la característica para realizar los distintos análisis de seguridad y corrección de estas, sin embargo, se comparte el presente documento, el cual, proporciona a los usuarios una guía detallada acerca de la configuración del prompt de StackHawk en conjunto con GitHub Copilot, al seguir estas indicaciones los usuarios aprovecharán al máximo las capacidades de la herramienta para proteger y reducir las vulnerabilidades en los sistemas.

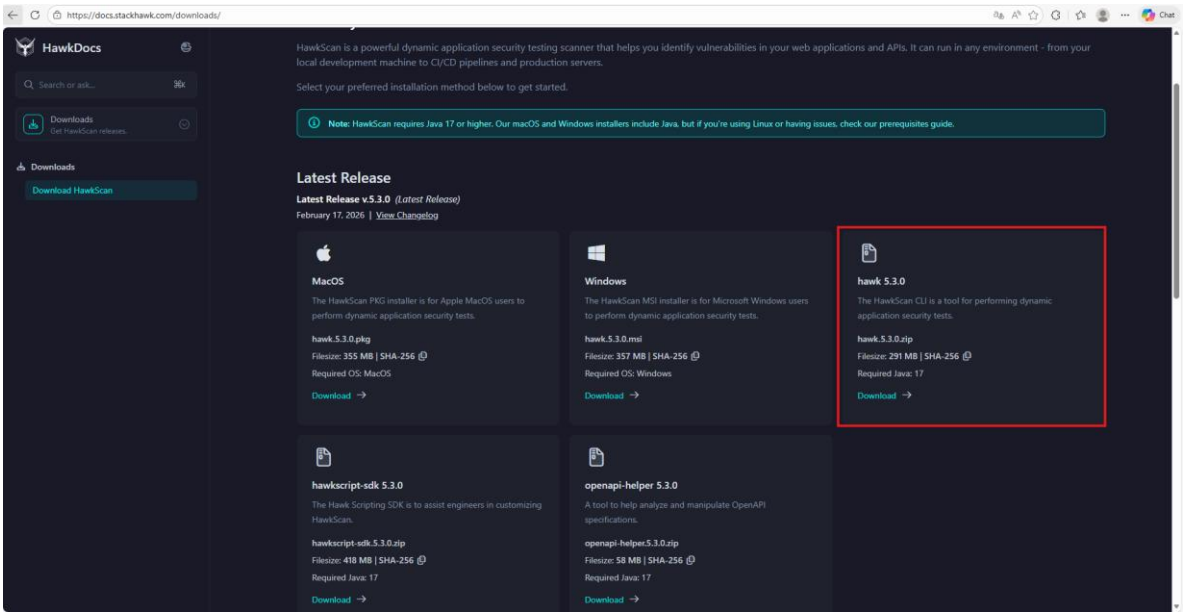
La descarga y configuración del CLI de la herramienta de StackHawk en su versión actual

NOTA: DESCARGAR LA ÚLTIMA VERSIÓN LIBERADA POR EL FABRICANTE.

La configuración de StackHawk se la puede realizar de dos formas diferentes:

Configuración manual:

Descargar la versión actual del CLI de StackHawk desde su página oficial [Download HawkScan | StackHawk Documentation] para Sistema Operativo Windows, Linux o MacOs, el archivo hawk-<VERSION ACTUAL>.zip (Seguir instructivo de instalación de StackHawk)



O configuración vía Ticket en el Service Now:

Link para la creación del ticket: Configuración de software - Employee Center

Descripción: Estimados, por favor su ayuda con la configuración del aplicativo HAWK para realizar pruebas de seguridad tipo DAST.

Otros campos: LLENAR LOS CAMPOS CON SU INFORMACIÓN.

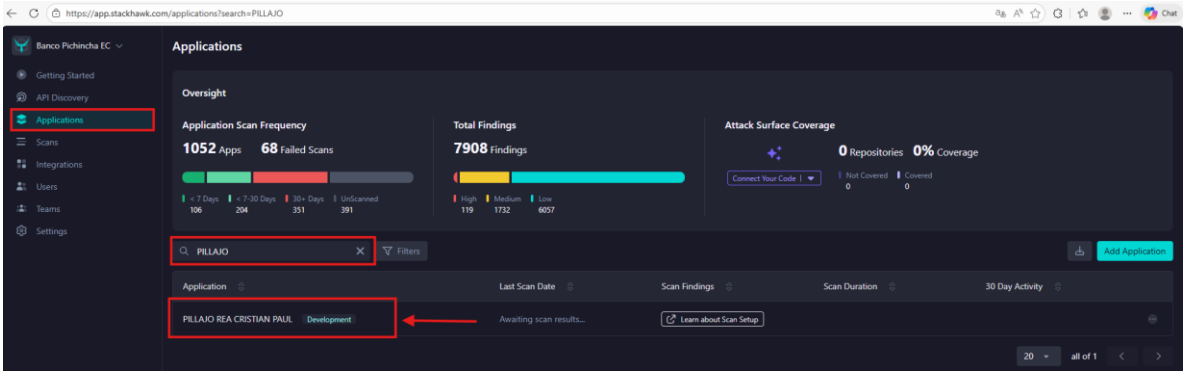
NOTA: En caso de que se solicite configuración vía ticket validar previamente que no tenga creado variables de entorno con la referencia a “hawk”.

Configuración previa de StackHawk

Acceder a plataforma de StackHawk para obtener su ID de aplicación y Api Key para crear dos variables de entorno en la cuenta de usuario.

Realizar login vía SSO: auth.stackhawk.com/sso

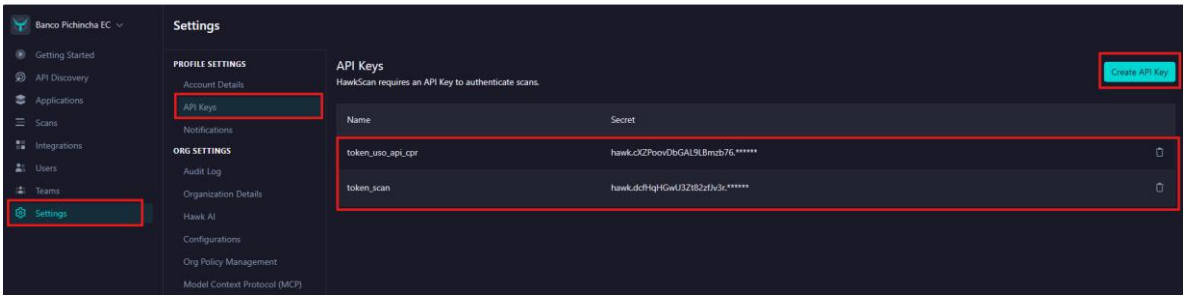
Buscar la aplicación que tiene su nombre: (StackHawk)



Obtener el id de aplicación

NOTA: En caso de no encontrar su nombre como aplicación comuníquese con el equipo de desarrollo seguro.

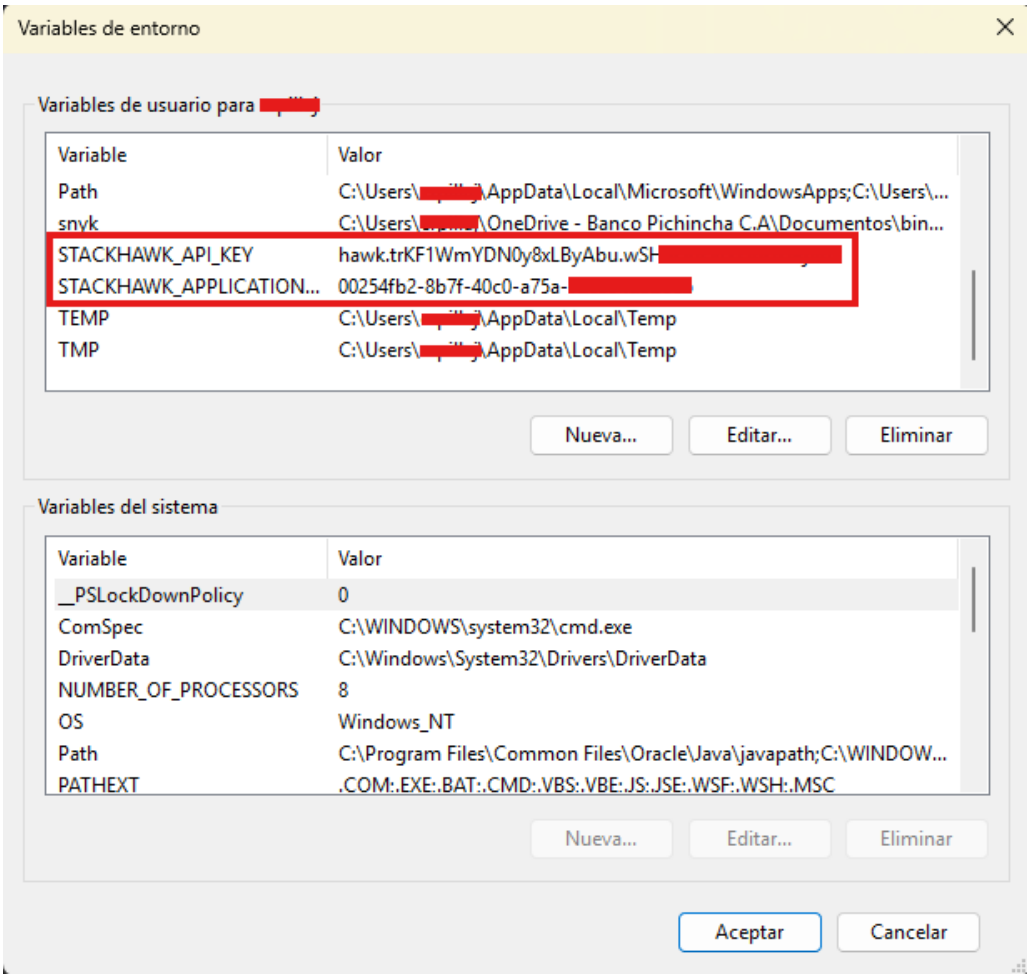
Obtener API KEY (StackHawk)



Una vez que se obtengan los dos datos (id de aplicación y api key) crear dos variables de entorno con los siguientes nombres:

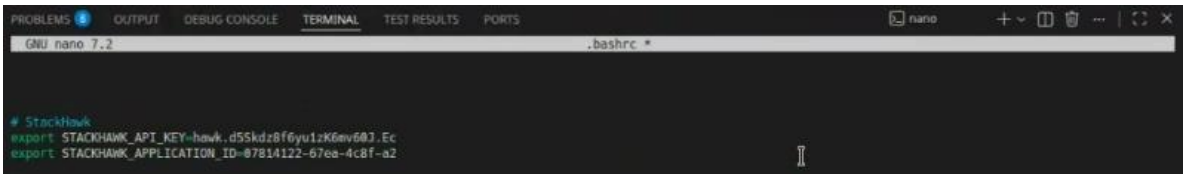
“STACKHAWK_API_KEY” y “STACKHAWK_APPLICATION_ID”

Windows



Linux, MacOs

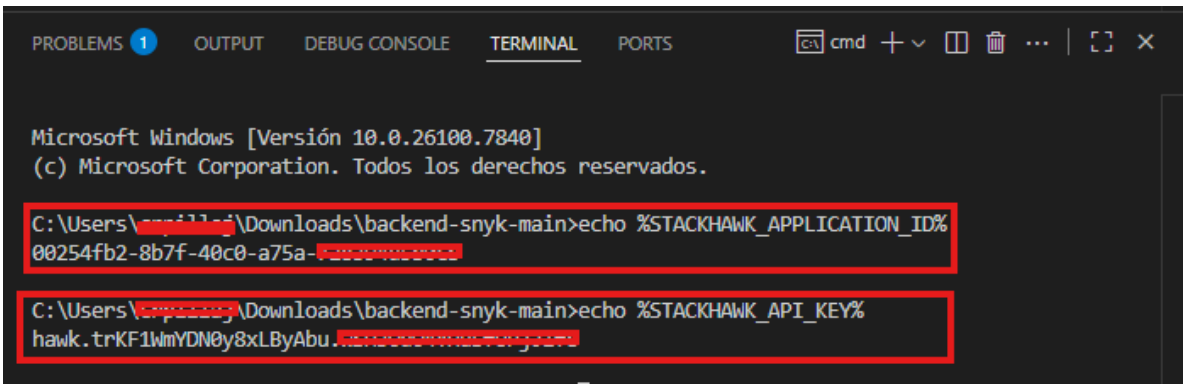
Colocar las variables de entorno que se encuentran en el directorio personal (~/), dependiendo de su SO: “~/.bashrc” o “~/.zshrc”.



Uso del PROMPT de StackHawk + GitHub Copilot

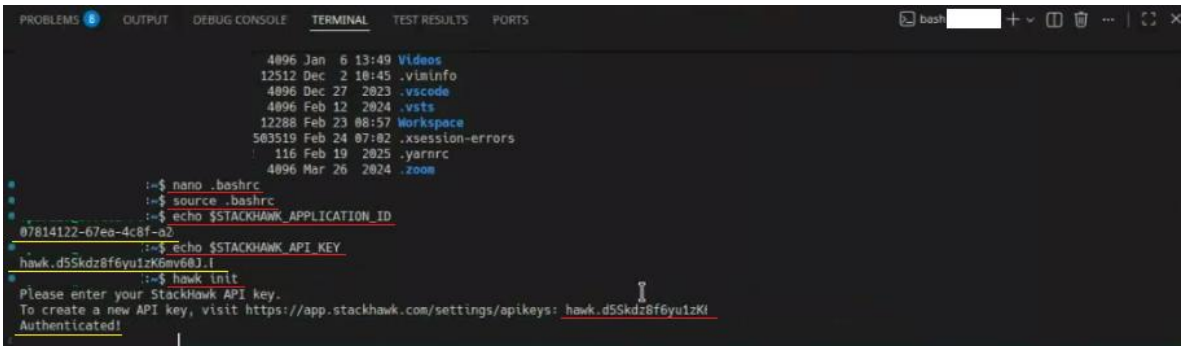
Paso 1) Validar que en la terminal del IDE de desarrollo reconozca las variables previamente creadas

Windows



Linux, MacOS

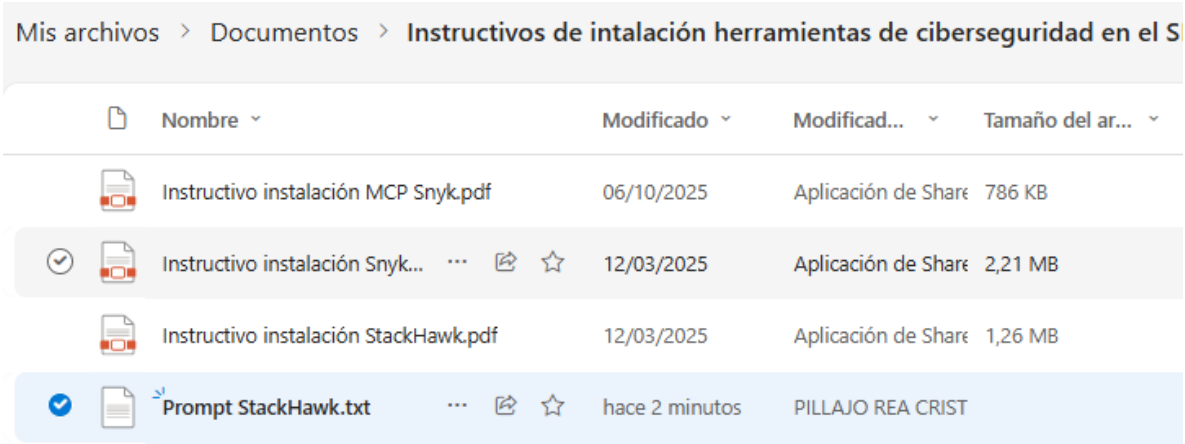
Guardar y refrescar las variables con el comando “source” y validar que en la terminal se pueda utilizar las variables de entorno.



Paso 2) IMPORTANTE Levantar el proyecto en su máquina local o ambiente de desarrollo

Paso 3) Ejecutar el promt en un chat nuevo de GitHub Copilot:

Link Promt StackHawk: [Prompt StackHawk.txt]



NOTA: Validar que los campos “applicationId” y “host” (Domio/IP y puerto del lugar donde se levantó el aplicativo) sean los correctos al momento que GitHub Copilot cree los archivos o de ser necesario cambiar de valores previo a realizar el análisis.

```
! stackhawk.yml > {} app > host
  StackHawk Scanner Configuration - StackHawk Scanner configuration files (hawkconfig.json)
1 app:
2   applicationId: 00254fb2-8b7f-40c0-a75a
3   env: Development
4   host: http://localhost:3000
5   openApiConf:
6     filePath: openapi-stackhawk.yml
```

NOTA: **Esperar** que StackHawk finalice el escaneo de forma exitosa para **continuar** con la presentación de resultados.

Paso 4) Visualización de resultados

✓ Read stackhawk-alerts.json

SUMMARY

Name	Severity	CWE
.htaccess Information Leak	Medium	94
X-Content-Type-Options Header Missing	Low	693
Server Leaks Information via "X-Powered-By" Header	Low	200
Content Security Policy (CSP) Header Not Set	Medium	693
Cross-Domain Misconfiguration	Medium	264
Missing Anti-clickjacking Header	Medium	1021

Total vulnerabilities count: 6

DETAILED VULNERABILITIES

1. .htaccess Information Leak

- Severity: Medium
- CWE: 94
- Scan finding URL: https://app.stackhawk.com/scans/26b205c7-df7b-4e73-8bad-0c24c9037df3/finding/40032-1
- Affected Paths: Typically `/` or any directory with exposed `.htaccess` (check `/upload`, test, `/vulnerability-snyk`)
- Description: .htaccess files are accessible via browser, exposing server config details.
- Recommendation: Restrict access, move configs to vhost, set permissions, remove sensitive content, use alternative locations.
- References:
  - https://developer.mozilla.org/en-US/docs/Learn/Server-side/Apache_Configuration_htaccess
  - https://httpd.apache.org/docs/2.4/howto/htaccess.html

2. X-Content-Type-Options Header Missing

- Severity: Low

2 files changed

! openapi-stackhawk.yml

! stackhawk.yml

FINAL RECOMMENDATIONS

- Prioritize fixing Medium vulnerabilities first (.htaccess leak, CSP, CORS, clickjacking).
- Harden server headers: remove `X-Powered-By`, add `X-Content-Type-Options`, CSP, and anti-clickjacking headers.
- Restrict CORS to trusted domains only.
- Regularly review exposed files and directories.
- Integrate DAST scans into CI/CD for continuous security validation.

SCAN INFO

- Scan ID: 26b205c7-df7b-4e73-8bad-0c24c9037df3
- Scan Status: COMPLETED
- Scan URL: https://app.stackhawk.com/scans/26b205c7-df7b-4e73-8bad-0c24c9037df3

CLEANUP

All scan and config files will be deleted as per instructions.

```
del /F /Q stackhawk-scan.json stackhawk-alerts.json stackhawk-login.json stackhawk-dev.yml
stackhawk-local.yml stackhawk-test.yml openapi-stackhawk.yml stackhawk.yml
```

NOTA: Es necesario que cada usuario revise las recomendaciones generadas previamente por el PROMPT de StackHawk + GitHub Copilot, antes de aplicar las modificaciones en la aplicación/código, con la finalidad de validar los cambios a modificar y su respectivo impacto.

Conclusión

La configuración del prompt de StackHawk se presenta como una solución para salvaguardar la integridad de los sistemas y mitigar las vulnerabilidades durante el desarrollo de software, promoviendo así un entorno de codificación seguro para reducir el riesgo de exposición a vulnerabilidades conocidas.

Enlace de la página de StackHawk y su documentación para obtener más información:

- Welcome to HawkDocs | StackHawk Documentation
- StackHawk | Shift-Left DAST & AppSec Intelligence

Link de acceso a los instructivos de instalación de herramientas de ciberseguridad en el SDLC:

- Instructivos de instalación herramientas de ciberseguridad en el SDLC